

Безопасность веб-приложений: Как связать OWASP Top 10 с требованиями ОАЦ по защите информации

 redsec.by/article/bezopasnost-veb-prilozhenij-kak-svyazat-owasp-top-10-s-trebovaniyami-oac-po-zashite-informacii

Red Teams | 24 октября 2025



Почему уязвимости веб-приложений — это не только техническая проблема

Когда специалист по информационной безопасности получает отчет из Burp Suite или Acunetix с перечнем найденных уязвимостей, таких как SQL-инъекции, XSS или небезопасные конфигурации, перед ним встает сложная, но критически важная задача. Ему необходимо не просто передать этот список разработчикам, но и "перевести" технические находки на язык бизнеса и регуляторов. Как превратить сухие строки отчета сканера в весомые аргументы для руководства и неоспоримые доказательства для аудита Оперативно-аналитического центра при Президенте Республики Беларусь (ОАЦ)?

Проблема заключается в фундаментальном разрыве коммуникации: разработчики, ИБ-специалисты, менеджмент и аудиторы ОАЦ часто говорят на разных языках. Для программиста SQL-инъекция — это ошибка в коде, которую нужно исправить. Для аудитора ОАЦ — это прямое нарушение требований по контролю доступа к данным и обеспечению целостности информации, четко закрепленных в приказе ОАЦ №66. Без этого "перевода" запросы на выделение ресурсов для исправления уязвимостей могут быть проигнорированы, а процесс прохождения аттестации превращается в формальное закрытие пунктов на бумаге, не имеющее ничего общего с реальной защищенностью.

Статистика лишь подчеркивает остроту проблемы. Согласно данным проекта OWASP за 2021 год, 94% протестированных приложений имели те или иные проблемы с контролем доступа (уязвимость A01:2021 — Broken Access Control). Хотя классические инъекции (Injection) опустились на третье место, они остаются критической угрозой. А межсайтовый скриптинг (XSS), по данным MITRE, возглавил список 25 самых опасных уязвимостей программного обеспечения в 2024 году.

Эта статья призвана стать мостом между мирами технического анализа и нормативного соответствия. Мы построим практический фреймворк, который позволит вам:

- **Понять**, какой конкретный пункт ТНПА Республики Беларусь нарушает каждая уязвимость из списка OWASP Top 10.
- **Превратить** результаты автоматического сканирования и ручного пентеста в аргументированные требования к команде разработки.
- **Подготовить** исчерпывающую доказательную базу для успешного прохождения аттестации системы защиты информации по требованиям ОАЦ.

OWASP Top 10 (2021): Краткий обзор главных угроз

Прежде чем перейти к сопоставлению, необходимо четко понимать, о каких угрозах идет речь. OWASP Top 10 — это не просто список, а результат консенсуса ведущих мировых экспертов в области кибербезопасности, основанный на анализе данных о реальных атаках и уязвимостях. Версия 2021 года, актуальная и на 2025 год, выглядит следующим образом:

Позиция	Название уязвимости	Краткое описание
A01:2021	Broken Access Control (Нарушение контроля доступа)	Пользователи получают доступ к данным или функциям, которые им не предназначены.
A02:2021	Cryptographic Failures (Недостатки криптографии)	Слабая защита конфиденциальных данных из-за использования устаревших алгоритмов или отсутствия шифрования.
A03:2021	Injection (Инъекции)	Внедрение вредоносного кода (SQL, NoSQL, OS command, LDAP) через пользовательский ввод.
A04:2021	Insecure Design (Небезопасный дизайн)	Архитектурные недостатки и отсутствие моделирования угроз на этапе проектирования.
A05:2021	Security Misconfiguration (Небезопасная конфигурация)	Дефолтные пароли, включенные отладочные режимы, избыточные права доступа.
A06:2021	Vulnerable and Outdated Components (Уязвимые компоненты)	Использование библиотек и фреймворков с известными, но неисправленными уязвимостями.
A07:2021	Identification and Authentication Failures (Ошибки аутентификации)	Слабые пароли, отсутствие MFA, некорректное управление сессиями.
A08:2021	Software and Data Integrity Failures (Нарушение целостности)	Отсутствие проверки целостности обновлений, небезопасные CI/CD пайплайны.
A09:2021	Security Logging and Monitoring Failures (Недостатки логирования)	Отсутствие или недостаточность журналирования событий безопасности.
A10:2021	Server-Side Request Forgery (SSRF)	Уязвимость позволяет атакующему заставить приложение отправлять запросы к внутренним ресурсам сети.

Требования ОАЦ: Краткий обзор нормативной базы

Для построения соответствия необходимо понимать, с какими именно требованиями мы работаем. Основу нормативной базы Республики Беларусь в области защиты информации составляют:

- **Указ Президента РБ №196 от 16.04.2013 (в редакции Указа №449 от 09.12.2019)** — определяет общие меры по совершенствованию использования национального сегмента сети Интернет и защиты информации.
- **Приказ ОАЦ №66 от 20.02.2020** — ключевой документ, утверждающий Положение о порядке технической и криптографической защиты информации и Положение о порядке аттестации систем защиты. Именно в нем содержатся конкретные технические требования.
- **Приказ ОАЦ №130 от 25.07.2023** — детализирует требования к центрам кибербезопасности (SOC) и порядку взаимодействия в рамках реализации Указа №40 "О кибербезопасности".
- **Приказ ОАЦ №259 от 10.12.2024** — вносит важные изменения и уточнения в Приказ №66, которые вступили в силу с 1 марта 2025 года.

Центральное место в нашем анализе занимает **пункт 7 Приказа ОАЦ №66**, который перечисляет обязательные требования к системе защиты информации:

- **7.1** — Идентификация и аутентификация
- **7.2** — Управление (контроль) доступом
- **7.3** — Ограничение программной среды
- **7.5** — Регистрация событий безопасности
- **7.8** — Контроль (анализ) защищенности информации
- **7.9** — Обеспечение целостности
- **7.10** — Обеспечение доступности
- **7.13** — Защита информационной системы и ее компонентов
- **7.14** — Управление конфигурацией
- **7.16** — Криптографическая защита информации
- **7.17** — Защита информации при взаимодействии информационных систем

Теперь, вооружившись знаниями об угрозах и требованиях, мы можем приступить к их детальному сопоставлению.

Связь OWASP Top 10 с требованиями ОАЦ: Детальный разбор

A01:2021 — Broken Access Control (Нарушение контроля доступа)

Что это такое: Самая распространенная категория уязвимостей, при которой пользователи могут выполнять действия или получать доступ к данным, на которые у них нет прав.

Примеры:

- Изменение параметра в URL (/user/profile?id=123 на /user/profile?id=124) для просмотра чужого профиля (IDOR - Insecure Direct Object Reference).
- Эскалация привилегий, когда обычный пользователь через уязвимость получает права администратора.
- Прямой доступ к API-методам без проверки авторизации текущего пользователя.

Какие требования ОАЦ нарушаются:

- **Пункт 7.2 — Управление (контроль) доступом субъектов доступа к объектам доступа:** Это прямое и наиболее очевидное нарушение. Система не обеспечивает разграничение доступа к информации и функциям, нарушая принцип минимальных привилегий.
- **Пункт 7.1 — Идентификация и аутентификация:** Нарушается, если уязвимость позволяет обойти проверку подлинности пользователя или действовать от имени другого пользователя.
- **Пункт 7.9 — Обеспечение целостности... информации:** Нарушается, если уязвимость позволяет несанкционированно изменять или удалять чужие данные.

Аргументация для аудита:

Формулировка для отчета: «Выявлена критическая уязвимость типа Broken Access Control (IDOR) в модуле управления профилями. Аутентифицированный пользователь может получить доступ к персональным данным любого другого пользователя путем перебора значения параметра userId в API-запросе /api/users/{userId}.

Нарушения требований приказа ОАЦ №66:

- **Пункт 7.2:** Не обеспечен надлежащий контроль доступа субъектов к объектам. Система не проверяет, совпадает ли userId из запроса с идентификатором авторизованного пользователя.
- **Пункт 7.9:** Создается угроза нарушения целостности информации, так как уязвимость позволяет не только читать, но и модифицировать чужие данные через связанные API-методы (PUT, DELETE).

Рекомендация: Реализовать на стороне сервера обязательную проверку прав доступа. Перед выполнением любого действия с объектом система должна убедиться, что текущий аутентифицированный пользователь является владельцем этого объекта».

Что это такое: Уязвимости, связанные с недостаточной защитой конфиденциальных данных (паролей, персональных данных, финансовых сведений) как при хранении, так и при передаче.

Примеры:

- Передача логинов и паролей по протоколу HTTP без шифрования TLS/SSL.
- Хранение паролей пользователей в базе данных в открытом виде или с использованием устаревших алгоритмов хеширования (например, MD5).
- Отсутствие шифрования для резервных копий, содержащих чувствительную информацию.

Какие требования ОАЦ нарушаются:

- **Пункт 7.16 — Криптографическая защита информации:** Прямое нарушение, так как не обеспечивается конфиденциальность и целостность информации с использованием криптографических средств при ее передаче и хранении.
Важно: В РБ для защиты государственных секретов и персональных данных требуется использование сертифицированных ОАЦ средств криптографической защиты.
- **Пункт 7.13 — Защита информационной системы и ее компонентов:**
Передача данных по незащищенным каналам ставит под угрозу всю систему.

Аргументация для аудита:

Формулировка для отчета: «Выявлено нарушение требований криптографической защиты: форма авторизации и страница восстановления пароля передают учетные данные пользователей по незащищенному протоколу HTTP. Это позволяет злоумышленнику, находящемуся в том же сегменте сети, перехватить пароли в открытом виде (атака "человек посередине").»

Нарушения требований приказа ОАЦ №66:

- **Пункт 7.16:** Не обеспечена криптографическая защита аутентификационных данных при их передаче по каналам связи.
- **Нарушение Закона РБ "О защите персональных данных":** Обработка персональных данных (включая логин/пароль) должна осуществляться с применением аттестованной системы защиты.

Рекомендация: Обеспечить использование протокола TLS (версии 1.2 и выше) на всех страницах веб-приложения. Настроить HTTP Strict Transport Security (HSTS) для принудительного использования HTTPS».

Что это такое: Одна из старейших и самых опасных уязвимостей, возникающая, когда недоверенные данные, полученные от пользователя, передаются интерпретатору как часть команды. Самый известный пример — SQL-инъекция.

Последствия: Раскрытие, модификация или удаление всех данных в базе, обход аутентификации, выполнение команд на сервере.

Какие требования ОАЦ нарушаются:

- **Пункт 7.2 — Управление (контроль) доступом:** SQL-инъекция в форме входа позволяет полностью обойти механизм аутентификации и получить несанкционированный доступ.
- **Пункт 7.9 — Обеспечение целостности информации:** Атакующий может выполнять запросы UPDATE, DELETE, DROP, нарушая целостность и доступность данных.
- **Пункт 7.8 — Контроль (анализ) защищенности информации:** Наличие такой уязвимости свидетельствует о недостатках в процессах безопасной разработки и тестирования.

Аргументация для аудита:

Формулировка для отчета: «Выявлена критическая уязвимость типа SQL Injection в форме поиска по сайту. Путем внедрения специально сформированного SQL-кода в параметр search_query атакующий может выполнить произвольные запросы к базе данных.

Proof of Concept (PoC): test' OR '1'='1' --

Нарушения требований приказа ОАЦ №66:

- **Пункт 7.2:** Уязвимость позволяет обойти контроль доступа к данным, извлекая информацию, не предназначенную для публичного просмотра.
- **Пункт 7.9:** Существует прямая угроза нарушения целостности информации.
- **Пункт 7.8:** Процессы контроля защищенности на этапе разработки неэффективны, так как не применяются базовые практики безопасного кодирования.

Рекомендации: Переписать код с использованием параметризованных запросов (prepared statements). Применять строгую валидацию входных данных. Ограничить привилегии учетной записи, от имени которой приложение подключается к БД».

Полный детальный разбор для каждой из 10 уязвимостей, включая Insecure Design, Security Misconfiguration, Vulnerable Components, Authentication Failures, Integrity Failures, Logging Failures и SSRF, будет следовать аналогичной структуре: простое объяснение, примеры, нарушаемые пункты Приказа №66 и готовая формулировка для аудиторского отчета с конкретными рекомендациями.

Практический фреймворк: От сканирования до отчета для ОАЦ

Теоретическое сопоставление — это хорошо, но как применить его на практике? Вот пошаговый алгоритм.

Шаг 1: Сканирование и ручной анализ

Используйте комбинацию инструментов для выявления максимального спектра уязвимостей:

- **DAST (Dynamic Application Security Testing) сканеры:** Burp Suite Professional, Acunetix, OWASP ZAP (бесплатный аналог). Они отлично находят "технические" уязвимости, такие как инъекции, XSS, небезопасные конфигурации.
- **SAST (Static Application Security Testing) инструменты:** Анализаторы исходного кода, которые находят уязвимости на этапе разработки.
- **SCA (Software Composition Analysis) инструменты:** OWASP Dependency-Check, Snyk. Они сканируют используемые библиотеки и фреймворки на наличие известных уязвимостей (A06:2021).
- **Ручное тестирование (пентест):** Незаменимо для выявления уязвимостей бизнес-логики, сложных цепочек атак и недостатков контроля доступа (A01:2021), которые автоматика часто пропускает.

Шаг 2: Классификация и приоритизация

После сбора данных сведите все найденные уязвимости в единую таблицу. Для каждой уязвимости укажите:

- Тип по классификации OWASP Top 10.
- Уровень критичности (CVSS-оценка).
- **Нарушенные пункты Приказа ОАЦ №66 (ключевой этап!).**
- Потенциальные риски для бизнеса (утечка ПДн, финансовые потери, репутационный ущерб).

Уязвимость	OWASP	Критичность	Нарушенные пункты ОАЦ №66	Риски для бизнеса
SQL-инъекция в логине	A03	Критическая	7.2, 7.9, 7.8	Компрометация всей БД, остановка работы сервиса
Просмотр чужих заказов	A01	Высокая	7.2, 7.9	Утечка персональных данных, нарушение Закона о ПД
Отсутствие HTTPS	A02	Высокая	7.16, 7.13	Перехват паролей и сессий пользователей
Устаревшая jQuery	A06	Средняя	7.8, 7.14	Эксплуатация известных XSS-уязвимостей

Шаг 3: Подготовка аргументированного отчета

Используйте структуру, понятную всем заинтересованным сторонам:

- **Резюме для руководства (Executive Summary):** Кратко, без технических деталей. Количество уязвимостей по уровням критичности, ключевые бизнес-риски, стоимость бездействия (штрафы, потери), самые срочные рекомендации.
- **Технический раздел:** Для каждой уязвимости используйте шаблон "Аргументация для аудита", описанный выше. Обязательно включите Proof of Concept (доказательство возможности эксплуатации), детальные шаги по воспроизведению и конкретные рекомендации по устранению.
- **Раздел соответствия требованиям ОАЦ:** Сводная таблица, наглядно демонстрирующая, какая уязвимость какой пункт ТНПА нарушает. Это ваш главный инструмент в диалоге с аудитором.

Шаг 4: Адресная коммуникация

Представляйте результаты по-разному:

- **Для разработчиков:** Фокус на технических деталях, PoC, примерах уязвимого и исправленного кода.
- **Для руководства:** Фокус на бизнес-рисках, финансовых потерях, нарушении законодательства и репутационном ущербе.
- **Для аудиторов ОАЦ:** Фокус на разделе соответствия, прямых ссылках на пункты Приказа №66 и доказательной базе.

Заключение: Безопасность как часть культуры, а не формальность

Безопасность веб-приложений — это не разовый аудит перед аттестацией, а непрерывный процесс, интегрированный в жизненный цикл разработки (DevSecOps). Создание моста между всемирно признанным стандартом OWASP Top 10 и специфическими требованиями белорусского законодательства позволяет решить сразу несколько стратегических задач:

- **Создать единый язык:** Разработчики, ИБ-специалисты, менеджмент и регуляторы начинают понимать друг друга.
- **Обосновать инвестиции:** Технические находки превращаются в весомые бизнес-аргументы, понятные руководству.
- **Приоритизировать ресурсы:** Устранение уязвимостей выстраивается не по желанию разработчиков, а на основе реальных рисков и требований законодательства.

Каждая уязвимость из списка OWASP Top 10 — это не просто теоретическая угроза, а прямое или косвенное нарушение как минимум одного, а чаще двух-трех, требований Приказа ОАЦ №66. SQL-инъекция — это не баг, а нарушение контроля доступа (п.7.2) и целостности (п.7.9). Отсутствие HTTPS при передаче персональных данных — прямое невыполнение требований по криптографической защите (п.7.16).

Внедряя регулярное сканирование, обучая разработчиков безопасному кодированию и используя предложенный фреймворк для подготовки к аттестации, вы не просто ставите галочки в чек-листе. Вы строите реальную, эшелонированную защиту, доказать эффективность которой сможете на любом уровне — от технического специалиста до аудитора ОАЦ.